TRƯỜNG ĐẠI HỌC VĂN LANG

KHOA CÔNG NGHỆ THÔNG TIN

BÁO CÁO ĐỒ ÁN

Môn học: Kiểm thử an ninh hệ thống mạng

Đề tài:

ĐÁNH GIÁ KHẢ NĂNG CHỐNG CHỊU TẤN CÔNG TỪ CHỐI DỊCH VỤ BẰNG KỸ THUẬT SYN FLOODING THEO PTES

Nhóm sinh viên thực hiện:

[1] 2274802010940 - Nguyễn Hoàng Thanh Trung

[2] 2274802011036 - Phạm Nguyễn Thanh Vy

[3] 2274802010666 - Lâm Xuân Phú

[4] 2174802010805 - Hồng Đăng Khoa

GVHD: ThS Bùi Duy cương

TP. Hồ Chí Minh – năm 2025

CỘNG HÒA XÃ HỘI CHỦ NGHĨA VIỆT NAM
Độc lập – Tự do – Hạnh phúc

PHIẾU NHẬN XÉT SINH VIÊN
CỦA GIẢNG VIÊN HƯỚNG DẪN

1. **Họ và tên sinh viên, mã số sinh viên:**

   2274802010940 - Nguyễn Hoàng Thanh Trung
   2274802011036 - Phạm Nguyễn Thanh Vy
   2274802010666 - Lâm Xuân Phú
   2174802010805 - Hồng Đăng Khoa
   Lớp: TTDL01
   Ngành: Mạng máy tính và truyền thông dữ liệu
   Giảng viên hướng dẫn: ThS Bùi Duy cương

2. **Nhận xét**:

   .....
   .....
   .....
   .....
   .....
   .....
   .....
   .....
   .....
   .....
   .....

TP. Hồ Chí Minh, ngày tháng năm 2025
Giảng viên hướng dẫn
(Ký và ghi rõ họ và tên)

MỤC LỤC

DANH MỤC HÌNH ẢNH 4
DANH MỤC BẢNG BIỂU 5
CHƯƠNG 1. MÔ TẢ ĐỒ ÁN 6
1.1 Tên đề tài 6
1.2 Bối cảnh – Lý do chọn đề tài 6
1.3 Mục tiêu của đồ án 6
1.4 Phạm vi thực hiện 7
1.5 Phương pháp thực hiện 7
1.6 Kết quả dự kiến đạt được 7
1.7 Ý nghĩa thực tiễn 7
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT 8
2.1 Quy trình kiểm thử PTES (Penetration Testing Execution Standard) 8
2.2 Khái niệm về tấn công từ chối dịch vụ (DDos-DoS Attack) 9
2.3 Quy trình kết nối TCP bắt tay 3 bước (Three-way handshake) 10
2.4 Kỹ thuận tấn công DoS - SYN Flooding 12
2.5 Phương thức hoạt động của SYN Flooding 13
2.6 Hậu quả của SYN Flooding 14
2.7 Giới thiệu các công cụ kiểm thử được sử dụng 16
2.7.1 Metasploit Framework 16
2.7.2 Nmap 17
2.7.3 Hping3 18
2.7.4 Wireshark 18
2.8 Phát hiện và phòng chống SYN Flooding. 19
2.9 Tổng kết chương 2 20
CHƯƠNG 3. KẾT QUẢ THỰC HIỆN 22

3.1 Kiểm thử khả năng chống chịu tấn công DoS bằng kỹ thuật SYN Flooding theo quy trình PTES 22
3.1.1 Kịch bản: "Tấn công DoS dịch vụ HTTP bằng Metasploit" 22
3.1.2 Mô hình kiểm thử 23
3.1.3 Giai đoạn 1 – Tiền kiểm thử (Pre-engagement) 25
3.1.4 Giai đoạn 2 – Thu thập thông tin (Information Gathering) 25
3.1.5 Giai đoạn 3 – Mô hình hóa mối đe dọa (Threat Modeling) 27
3.1.6 Giai đoạn 4 – Phân tích lỗ hổng (Vulnerability Analysis) 29
3.1.7 Giai đoạn 5 – Khai thác (Exploitation) 30
3.1.8 Giai đoạn 6 – Hậu khai thác (Post-exploitation) 33
3.1.9 Giai đoạn 7 – Tổng kết 34
3.2 Giải pháp phòng chống 35
3.3 Tổng kết chương 3 37
CHƯƠNG 4. KẾT LUẬN 39
TÀI LIỆU THAM KHẢO 41

DANH MỤC HÌNH ẢNH

Hình 2.1. Hình minh họa trực quan DDoS-DoS Attack 9
Hình 2.2. Mô tả quá trình bắt tay ba bước 10
Hình 2.3. Quy trình ngắt kết nối TCP (Four-way Termination) 11
Hình 2.4. Mô tả tấn công SynFlooding 14
Hình 2.5.Giới thiệu về Metasploit (nguồn: vietnix) 16
Hình 2.6. Giới thiệu nmap 17
Hình 2.7. Giới thiệu wireshark 18
Hình 3.1. Máy tấn công và công cụ tấn công metasploit 22
Hình 3.2. Máy nạn nhân với dịch vụ web bình thường 23
Hình 3.3. Kiểm tra phản hồi của mục tiêu 26
Hình 3.4. Do thám bằng lệnh curl và whatwweb 27
Hình 3.5. Mô hình DFD level 0 của tấn công 28
Hình 3.6. Bảng mối đe dọa Stride 28
Hình 3.7. Metasploit chuyển module thành công. 30
Hình 3.8. Cấu hình các tham số cần thiết. 30
Hình 3.9. Khai thác 30
Hình 3.10. Ghi nhận cuộc tấn công từ máy mục tiêu 31
Hình 3.11. Giao diện tấn công bằng công cụ hping3 32
Hình 3.12. Quan sát cuộc tấn công 33
Hình 3.13. Ảnh hưởng từ cuộc tấn công 33

DANH MỤC BẢNG BIỂU

Bảng 2.1. Mô tả 7 giai đoạn kiểm thử theo PTES 8
Bảng 3.1. Mô tả thành phần kiểm thử trong kịch bản 23
Bảng 3.2. Bảng mô tả giai đoạn tiền kiểm thử 25
Bảng 3.3. Bảng mô tả gia đoạn thu thập thông tin 25
Bảng 3.4. Bảng thành phần trong giai đoạn 3 27

CHƯƠNG 1. MÔ TẢ ĐỒ ÁN

1.1 Tên đề tài

Đánh giá khả năng chống chịu tấn công từ chối dịch vụ bằng kỹ thuật SYN Flooding theo PTES

1.2 Bối cảnh – Lý do chọn đề tài

Bằng việc kiểm thử và đánh giá mức độ ổn định và bảo mật của hệ thống sẽ thể hiện tính chuyên nghiệp của một tổ chức trong thế giới hiện đại nơi công nghệ đang dẫn đầu các xu hướng song song với đó là những mối đe dọa về thông tin dữ liệu ngày càng lớn. Tấn công từ chối dịch vụ (DoS) là một trong số mối đe dọa đó. Kẻ tấn công tấn công làm gián đoạn hệ thống ngày càng tinh vi với nhiều mục đích khác nhau. Việc nhận diện, mô phỏng và kiểm thử các hình thức tấn công như DoS, **đặc biệt là kỹ thuật SYN Flooding** – một dạng khai thác lỗ hổng trong quá trình bắt tay TCP – sẽ giúp tổ chức không chỉ phát hiện các điểm yếu trong hệ thống, mà còn có cơ sở để xây dựng các chiến lược phòng thủ hiệu quả hơn. Bên cạnh đó, **việc áp dụng các quy trình kiểm thử chuẩn hóa như PTES** giúp đảm bảo tính hệ thống, khách quan và có thể tái sử dụng trong nhiều tình huống thực tế khác nhau.

Việc lựa chọn đề tài này không chỉ mang ý nghĩa thực tiễn trong việc đảm bảo an toàn hệ thống, mà còn giúp chúng em rèn luyện kỹ năng phân tích, mô phỏng tấn công, và triển khai giải pháp bảo mật trong môi trường mạng thực tế.

1.3 Mục tiêu của đồ án

Mục tiêu chính của đồ án: Mô phỏng và kiểm thử tấn công SYN Flood để đánh giá khả năng phòng thủ của hệ thống.

Bên cạnh đó đồ án còn giúp sinh viên vận dụng kỹ thuật tấn công SYN Flooding đã được học, hiểu rõ hơn về quy trình kiểm thử bảo mật chuẩn hóa PTES. Từ đó nghiên cứu và đưa ra cái giải pháp phòng chống hiệu quả.

1.4 Phạm vi thực hiện

Đồ án được thực hiện trong môi trường ảo hóa với 2 máy ảo sandbox không triển khai thực tế.

1.5 Phương pháp thực hiện

Về lý thuyết:

- Trình bày các khái niệm lý thuyết về tấn công từ chối dịch vụ Dos, DdoS, khái niêm về Three-ways handshake, SYN Flooding và phương thức hoạt động.
- Mô tả sơ lược các công cụ sử dụng trong Pentest như Metasploit, nmap, wireshark,…

Về thực nghiệm:

- Mô phỏng cuộc tấn công DoS bằng kỹ thuật SYN Flooding.
- Đánh giá mức độ tổn thương của hệ thống.
- Đưa giải pháp phòng chống và thử nghiệm.

1.6 Kết quả dự kiến đạt được

- Mô phỏng thành công cuộc tấn công.
- Đánh giá mức độ ảnh hưởng và hiệu năng của Server.
- Đề xuất và áp dụng được giải pháp phòng thủ.

1.7 Ý nghĩa thực tiễn

Đồ án mạng lại giá trị thực tế trong việc nâng cao nhận thức, đánh giá an ninh hệ thông mạng trước các hình thức tấn công mạng phổ biến. Việc mô phỏng quá trình tấn công theo quy trình chuẩn PTES giúp sinh viên hiểu sâu hơn về nguyên lý hoạt động của TCP và cách các kỹ thuật tấn công khai thác điểm yếu của các giao thức hay hệ thống, từ đó giúp sinh viên nhận diện rõ về các rủi ro bảo mật.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1 Quy trình kiểm thử PTES (Penetration Testing Execution Standard)

PTES (Penetration Testing Execution Standard) là một tiêu chuẩn quốc tế hướng dẫn quy trình thực hiện kiểm thử xâm nhập một cách có hệ thống và chuyên nghiệp. PTES chia quá trình kiểm thử thành 7 giai đoạn:

Bảng 2.1. Mô tả 7 giai đoạn kiểm thử theo PTES

Giai đoạn	Mô tả ngắn gọn
Tiền kiểm thử	Xác định phạm vi, mục tiêu, giới hạn pháp lý và các rủi ro của kiểm thử
Thu thập thông tin	Tìm kiếm, phân tích thông tin hệ thống mục tiêu từ xa hoặc qua mạng nội bộ
Mô hình hóa mối đe dọa	Xác định tài sản quan trọng, điểm vào/ra và các mối đe dọa dựa theo STRIDE
Phân tích lỗ hổng	Dò quét và phát hiện các điểm yếu bảo mật trong hệ thống hoặc dịch vụ
Khai thác	Thực hiện tấn công vào các lỗ hổng để đánh giá khả năng bị xâm nhập
Hậu khai thác (Post-Ex)	Phân tích dữ liệu chiếm được, leo thang đặc quyền và duy trì truy cập hệ thống
Báo cáo (Reporting)	Tổng hợp kết quả, đánh giá rủi ro và đề xuất biện pháp khắc phục chi tiết

Việc tuân thủ quy trình PTES giúp bài tiểu luận có cấu trúc rõ ràng, thuyết phục, và bám sát phương pháp kiểm thử thực tế trong ngành an ninh mạng chuyên nghiệp.

2.2 Khái niệm về tấn công từ chối dịch vụ (DDos-DoS Attack)

Hình 2.1. Hình minh họa trực quan DDoS-DoS Attack

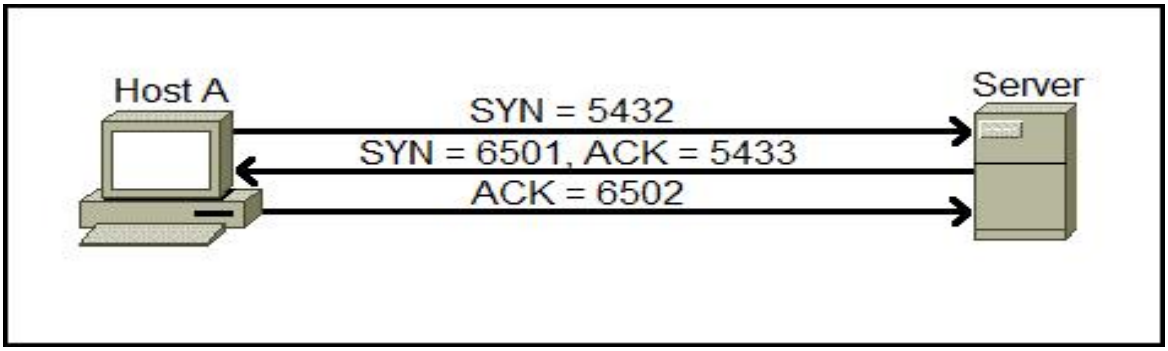


Tấn công từ chối dịch vụ (Denial of Service - DoS) là một hình thức tấn công mạng nhằm **làm gián đoạn** hoặc **làm ngừng hoạt động** bình thường của một hệ thống, dịch vụ hoặc mạng lưới bằng cách làm quá tải tài nguyên của hệ thống mục tiêu. **Mục tiêu chính** của cuộc tấn công này là **khiến cho các người dùng hợp pháp không thể truy cập hoặc sử dụng dịch vụ** như bình thường. Các cuộc tấn công DoS có thể khai thác nhiều điểm yếu khác nhau trong hệ thống, chẳng hạn như lỗ hổng phần mềm, giới hạn băng thông hoặc tài nguyên xử lý. Một biến thể phức tạp hơn của DoS là tấn công từ chối dịch vụ phân tán (Distributed Denial of Service - DDoS), trong đó kẻ tấn công sử dụng nhiều hệ thống bị chiếm quyền điều khiển để phát động cuộc tấn công đồng thời từ nhiều nguồn khác nhau, làm tăng đáng kể quy mô và mức độ phá hoại. Các cuộc tấn công DoS, dù đơn giản hay phức tạp, đều có thể gây ra thiệt hại đáng kể về kinh tế, uy tín và an ninh cho tổ chức bị ảnh hưởng.

2.3 Quy trình kết nối TCP bắt tay 3 bước (Three-way handshake)

Các cuộc tấn công SYN Flood hoạt động bằng cách khai thác quá trình bắt tay trong kết nối TCP. Cụ thể là quy trình **"Bắt tay ba bước (Three-way Handshake)",** đây là một quy trình nhằm đảm bảo cả hai bên đều sẵn sàng và biết được thông tin cần thiết để trao đổi dữ liệu một cách chính xác.

Hình 2.2. Mô tả quá trình bắt tay ba bước



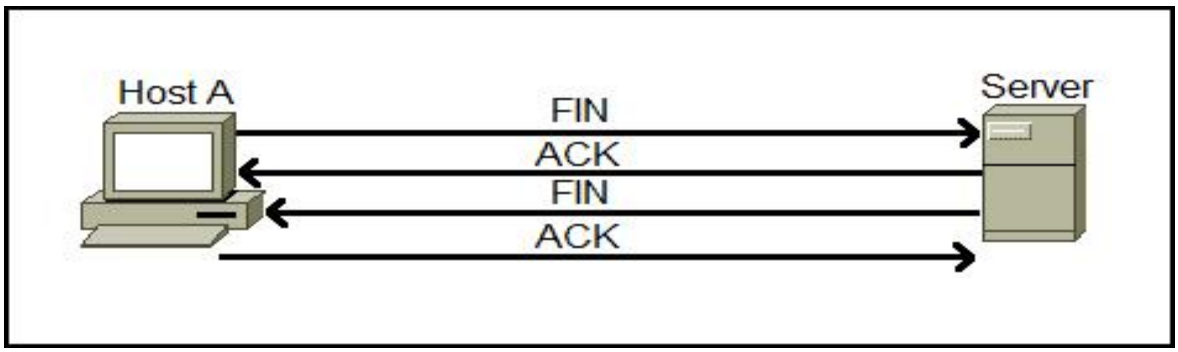
Bước 1: Máy khách A khởi tạo kết nối bằng cách gửi gói TCP có cờ **SYN = 1** đến máy chủ đích. Gói này **chứa số thứ tự khởi tạo (Initial Sequence Number) ngẫu nhiên** (ví dụ: 5432), đánh dấu sự bắt đầu của số thứ tự cho dữ liệu mà Máy khách A sẽ truyền.

Bước 2: Máy chủ nhận gói và phản hồi bằng một gói có cờ **SYN = 1 và ACK = 1**, chứa số thứ tự mới của chính nó (ví dụ: 1000), và **số xác nhận (ACK)** là số thứ tự của máy khách A cộng thêm 1 (ví dụ: 5433).

Bước 3: Máy khách A xác nhận phản hồi của máy chủ bằng cách gửi gói có cờ **ACK = 1**, kèm theo số xác nhận là số thứ tự của máy chủ cộng thêm 1 (ví dụ: 1001). **Lúc này, kết nối TCP chính thức được thiết lập.**

Sau khi quá trình truyền dữ liệu hoàn tất, TCP sẽ ngắt kết nối giữa 2 máy chủ. Quá trình ngắt kết nối TCP diễn ra như sau:

Hình 2.3. Quy trình ngắt kết nối TCP (Four-way Termination)



Bốn bước này được diễn tả như sau:

1. Ứng dụng từ máy khách muốn đóng kết nối sẽ gửi một segment TCP có cờ FIN = 1 (Hoàn thành)
2. Máy chủ nhận được segment TCP và xác nhận nó bằng **segment TCP có cờ ACK = 1**
3. Khi máy chủ cũng sẵn sàng đóng kết nối, nó gửi một segment TCP riêng với cờ FIN = 1 cho máy khách.
4. Máy khách xác nhận segment FIN của máy chủ bằng cách gửi lại một segment TCP có cờ ACK = 1, và sau đó đóng kết nối.

Lợi ích của quy tắc bắt tay 3 bước trong giao thức TCP:

- Đảm bảo kết nối đáng tin cậy (Reliable connection)
- Ngăn chặn phản hồi từ các gói bị giả mạo
- Đồng bộ hóa thông số truyền tải
- Giảm nguy cơ gửi trùng lặp dữ liệu

Nhược điểm:

- **Dễ bị khai thác bởi tấn công SYN Flood:** Giai đoạn server chờ ACK cuối cùng từ client chính là điểm yếu khiến nó dễ bị chiếm tài nguyên (kết nối "half-open").
- **Gây độ trễ trong kết nối:** Mất ít nhất ba lần truyền gói tin để thiết lập kết nối, dẫn đến độ trễ so với các giao thức không kết nối như UDP.

- **Yêu cầu tài nguyên duy trì trạng thái kết nối**: Server phải giữ thông tin trạng thái kết nối tạm thời cho mỗi SYN nhận được → dễ bị quá tải nếu không được bảo vệ đúng cách.
- **Không phù hợp với một số ứng dụng thời gian thực:** Các ứng dụng như video streaming, game hoặc VoIP yêu cầu kết nối nhanh.

2.4 Kỹ thuận tấn công DoS - SYN Flooding

SYN Flooding (Half-open attack) là một kỹ thuật tấn công từ chối dịch vụ (Denial of Service - DoS) hoặc tấn công từ chối dịch vụ phân tán (Distributed Denial of Service - DDoS) mục đích là làm cho máy chủ không thể phục vụ lưu lượng truy cập hợp pháp bằng cách gây quá tải máy chủ. Lợi dụng quá trình bắt tay ba bước, kẻ tấn công liên tục gửi các gói yêu cầu kết nối ban đầu (SYN) và có thể làm quá tải các cổng đang mở trên máy chủ mục tiêu, khiến thiết bị bị tấn công phản hồi chậm hoặc hoàn toàn không phản hồi với lưu lượng truy cập hợp pháp. Hình thức tấn công SYN Flooding có thể xảy ra theo 3 cách khác nhau:

Tấn công trực tiếp (Direct attack): Tấn công SYN Flood mà không giả mạo địa chỉ IP được gọi là tấn công trực tiếp. Trong hình thức này, kẻ tấn công không che giấu địa chỉ IP của mình. Do sử dụng một thiết bị duy nhất với địa chỉ IP thật để thực hiện tấn công, kẻ tấn công rất dễ bị phát hiện và ngăn chặn. Trong thực tế, phương pháp này hiếm khi được sử dụng vì việc đối phó rất đơn giản – chỉ cần chặn địa chỉ IP của attacker. Nếu kẻ tấn công sử dụng mạng botnet như Mirai, chúng thường không quan tâm đến việc ẩn địa chỉ IP của thiết bị bị nhiễm.

Tấn công phân tán (DDoS – Distributed attack): Khi cuộc tấn công được triển khai bằng mạng botnet, khả năng lần ra nguồn gốc là rất thấp. Để tăng thêm mức độ che giấu, kẻ tấn công có thể cho mỗi thiết bị trong mạng botnet giả mạo địa chỉ IP khi gửi gói tin. Tuy nhiên, nếu sử dụng botnet như Mirai, chúng thường không cần che giấu IP của các thiết bị bị nhiễm vì chúng là các máy chủ hoặc thiết bị IoT bị chiếm quyền điều khiển

Tấn công giả mạo địa chỉ IP (Spoofed attack): Kẻ tấn công có thể giả mạo địa chỉ IP trên mỗi gói SYN được gửi đi để gây khó khăn cho việc ngăn chặn và che giấu danh tính. Dù các gói tin có thể bị giả mạo, trong một số trường hợp, vẫn có thể lần theo dấu vết để truy ngược về nguồn gốc. Việc điều tra này rất khó khăn, nhưng không phải là bất khả thi, đặc biệt nếu các nhà cung cấp dịch vụ Internet (ISP) hợp tác hỗ trợ.

2.5 Phương thức hoạt động của SYN Flooding

Các cuộc tấn công SYN Flood khai thác quá trình bắt tay trong kết nối TCP. Trong điều kiện bình thường, kết nối TCP trải qua ba bước riêng biệt để thiết lập kết nối:

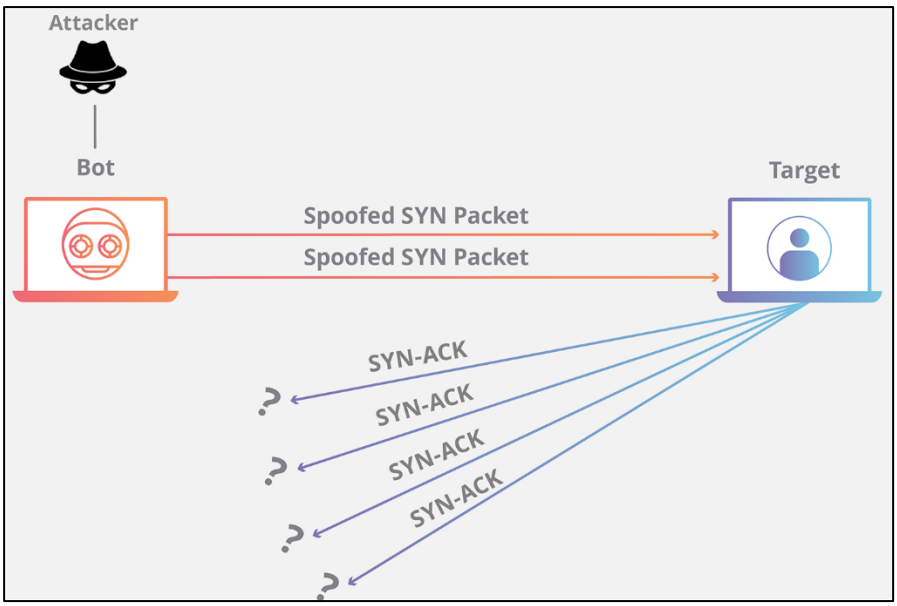
1. Đầu tiên, máy khách gửi một gói SYN đến máy chủ để khởi tạo kết nối.
2. Tiếp theo, máy chủ phản hồi lại gói SYN đó bằng một gói SYN/ACK để xác nhận yêu cầu kết nối.
3. Cuối cùng, máy khách gửi lại một gói ACK để xác nhận đã nhận được phản hồi từ máy chủ.

Để tạo ra tình trạng từ chối dịch vụ (DoS), kẻ tấn công khai thác thực tế rằng sau khi nhận được gói SYN ban đầu, máy chủ sẽ phản hồi bằng một hoặc nhiều gói SYN/ACK và **chờ bước cuối cùng trong quy trình bắt tay**. Cách thức hoạt động như sau:

1. Kẻ tấn công gửi một lượng lớn gói SYN đến máy chủ mục tiêu, thường sử dụng các địa chỉ IP giả mạo (spoofed).
2. Máy chủ phản hồi lại mỗi yêu cầu kết nối bằng cách gửi gói SYN/ACK và mở một cổng để chờ nhận phản hồi.
3. Trong khi máy chủ chờ gói ACK cuối cùng – vốn không bao giờ đến – kẻ tấn công tiếp tục gửi thêm các gói SYN khác.

Việc mỗi gói SYN mới đến khiến máy chủ phải duy trì tạm thời một kết nối mở trong một khoảng thời gian nhất định. Khi tất cả các cổng sẵn có đều bị chiếm dụng, máy chủ không thể hoạt động bình thường nữa.

Hình 2.4. Mô tả tấn công SynFlooding



Trong lĩnh vực mạng máy tính, khi một máy chủ duy trì kết nối mở nhưng máy ở phía bên kia của kết nối lại không phản hồi, **kết nối đó được gọi là kết nối nửa mở (half-open)**. Trong loại tấn công DDoS này, máy chủ mục **tiêu liên tục để ngỏ các kết nối** và **chờ đợi từng kết nối hết thời gian chờ (timeout)** trước khi các cổng đó có thể được sử dụng lại. Kết quả là loại tấn công này được gọi là **"tấn công nửa mở" (half-open attack).**

Thay vì các cuộc tấn công số lượng lớn nhằm mục đích bão hòa cơ sở hạ tầng mạng xung quanh mục tiêu, các cuộc tấn công SYN chỉ cần lớn hơn lượng backlog có sẵn trong hệ điều hành của mục tiêu. Nếu kẻ tấn công có thể xác định kích thước của backlog và thời gian mỗi kết nối sẽ được mở trước khi hết thời gian chờ, kẻ tấn công có thể nhắm mục tiêu các tham số chính xác cần thiết để vô hiệu hóa hệ thống, từ đó giảm tổng lưu lượng truy cập xuống mức tối thiểu cần thiết để tạo từ chối dịch vụ.

2.6 Hậu quả của SYN Flooding

Các cuộc tấn công SYN Flooding có chủ đích có thể gây ra các hậu quả sau:

- **Làm gián đoạn dịch vụ (Service Disruption):** Máy chủ bị quá tải không thể phản hồi các yêu cầu kết nối hợp pháp từ người dùng. Các

dịch vụ như website, API, email, ứng dụng... bị treo, chậm hoặc sập hoàn toàn.

- **Mất quyền truy cập cho người dùng hợp pháp:** Các kết nối nửa mở chiếm hết tài nguyên, khiến người dùng thật không thể kết nối đến dịch vụ. Điều này đặc biệt nghiêm trọng đối với các hệ thống thời gian thực như: ngân hàng, thương mại điện tử, y tế, dịch vụ công.
- **Hao tổn tài nguyên hệ thống:** SYN Flooding chiếm dụng bộ nhớ, CPU, socket và bảng kết nối tạm thời (backlog queue). Nếu kéo dài, máy chủ có thể ngừng hoạt động hoặc phải khởi động lại.
- **Tổn thất kinh tế và uy tín:** Website bị gián đoạn trong giờ cao điểm dẫn đến mất doanh thu trực tiếp. Làm giảm uy tín thương hiệu trong mắt khách hàng, đối tác. Tăng chi phí cho nhân sự IT, bảo trì và nâng cấp hạ tầng.
- **Tạo điều kiện cho các cuộc tấn công khác:** Khi máy chủ đang "bận" xử lý các gói SYN giả, kẻ tấn công có thể: Thực hiện tấn công kết hợp như brute force, SQL injection; Đánh lạc hướng hệ thống giám sát, mở đường cho việc xâm nhập.
- Gây áp lực cho cơ sở hạ tầng mạng: Lượng lớn lưu lượng SYN khiến thiết bị tường lửa, router, switch bị quá tải. Có thể ảnh hưởng đến toàn bộ mạng nội bộ, không chỉ riêng máy chủ mục tiêu.

Các ví dụ thực tế:

- **Amazon Web Service:** Vào năm 2020, Amazon Web Service báo cáo đã ngăn chặn một cuộc tấn công SYN Flooding lên tới 2.3 Tbps – đó được xem là cuộc tấn công DDoS lớn nhất từng được ghi nhận tính đến thời điểm đó.
- **Dyn, nhà cung cấp dịch vụ DNS lớn, bị tấn công DDoS** dẫn đến mất truy cập tạm thời cho các website lớn như Twitter, Netflix, Reddit... Dù không công bố cụ thể, các **gói SYN và TCP** là thành phần chính trong phần lớn các cuộc DDoS quy mô lớn.

- Nhiều **ngân hàng trong khu vực tại Việt Nam và Đông Nam Á đã từng bị tấn công DDoS** sử dụng SYN Flood nhằm **gây gián đoạn dịch vụ ngân hàng** trực tuyến.

Tóm lại tấn công từ chối dịch vụ bằng kỹ thuật SYN Flooding đã và đang là mối đe dọa về tính sẵn sàng của hệ thống dịch vụ mạng của các tổ chức, doanh nghiệp tại Việt Nam cũng như trên thế giới.

2.7 Giới thiệu các công cụ kiểm thử được sử dụng

2.7.1 Metasploit Framework

Hình 2.5.Giới thiệu về Metasploit (nguồn: vietnix)



Metasploit Framework là nền tảng mã nguồn mở do Rapid7 phát triển, dùng để phát triển, kiểm thử và khai thác lỗ hổng bảo mật. Công cụ này hỗ trợ pentest, nghiên cứu lỗ hổng và huấn luyện an ninh mạng.

Thành phần chính:

- **Exploits:** Mã khai thác lỗ hổng.
- **Payloads:** Mã thực thi khi khai thác thành công (như Meterpreter, reverse shell).
- **Auxiliary Modules:** Quét, dò mật khẩu, DoS…
- **Post-Exploitation Modules:** Thu thập thông tin, leo thang đặc quyền, tạo backdoor.

Cách sử dụng:

- **msfconsole** (CLI)**, msfvenom** (tạo payload), **GUI** (Armitage/Cobalt Strike).

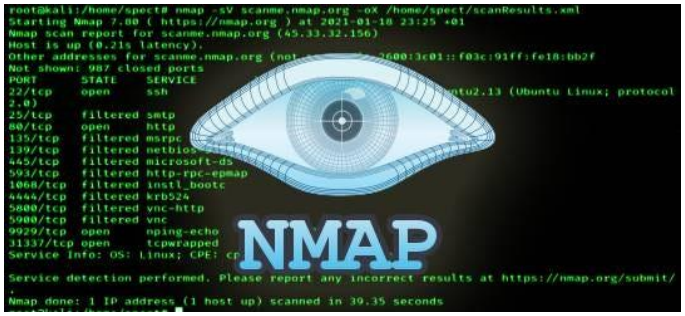
Ứng dụng: Pentest, đào tạo, kiểm tra phòng thủ, nghiên cứu bảo mật.

Ưu điểm: Miễn phí, cộng đồng lớn, cập nhật thường xuyên.

Hạn chế: Có thể bị lạm dụng, một số exploit đã cũ.

2.7.2 Nmap

Hình 2.6. Giới thiệu nmap



Nmap (Network Mapper) là công cụ mã nguồn mở dùng để quét và phân tích mạng, do Gordon Lyon (Fyodor) phát triển. Nmap giúp quản trị viên và chuyên gia bảo mật phát hiện thiết bị, dịch vụ, hệ điều hành và lỗ hổng trên mạng.

Chức năng chính:

- Phát hiện host đang hoạt động (Host Discovery).
- Quét cổng và xác định dịch vụ đang chạy (Port Scanning, Service Detection).
- Xác định hệ điều hành (OS Detection).
- Phát hiện lỗ hổng thông qua script (Nmap Scripting Engine – NSE).

Cách sử dụng:

- Chạy qua dòng lệnh (nmap [options] target).

Tùy chọn phổ biến:

- -sS (SYN Scan), -sV (Service Version), -O (OS Detection), -A (Aggressive Scan).

Ứng dụng:

- Quản trị mạng: Kiểm kê và giám sát hệ thống.
- Pentest: Thu thập thông tin trước khi khai thác.
- Kiểm tra bảo mật: Phát hiện dịch vụ không cần thiết hoặc lỗ hổng.

Ưu điểm: Miễn phí, mạnh mẽ, hỗ trợ nhiều hệ điều hành.

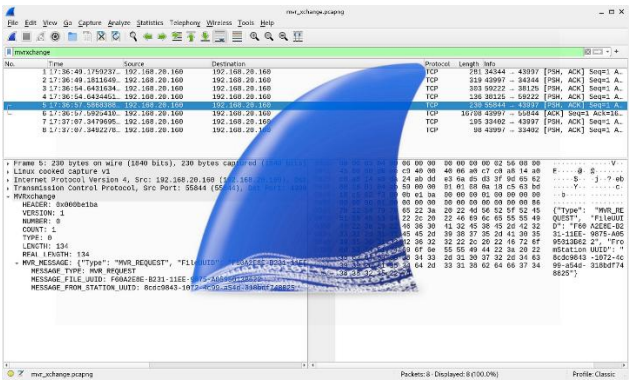
Hạn chế: Có thể bị IDS/Firewall phát hiện, mất nhiều thời gian khi quét mạng lớn.

2.7.3 Hping3

Hping3 - Công cụ quét mạng và máy phân tích cho giao thức TCP/IP được phân phối bởi Salvatore Sanfilippo (còn được gọi là Antirez). Công cụn này phân tích gói tin TCP/IP theo định hướng dòng lệnh, hping không chỉ có thể gửi các yêu cầu echo ICMP mà còn hỗ trợ giao thức TCP, UDP, ICMP và RAW-IP, có chế độ traceroute, khả năng gửi tập tin giữa một kênh được bảo vệ và nhiều tính năng khác.

2.7.4 Wireshark

Hình 2.7. Giới thiệu wireshark



Wireshark là công cụ phân tích gói tin mạng mã nguồn mở, dùng để thu thập và hiển thị dữ liệu mạng theo thời gian thực. Công cụ này hỗ trợ nhiều giao thức và được sử dụng rộng rãi trong quản trị mạng, kiểm thử bảo mật và phân tích sự cố.

Chức năng chính:

- **Packet Capture:** Ghi lại toàn bộ gói tin trên giao diện mạng.

- **Packet Analysis:** Giải mã hàng trăm giao thức mạng khác nhau.
- **Lọc và tìm kiếm:** Dùng bộ lọc hiển thị (Display Filter) để phân tích chính xác dữ liệu cần tìm.
- **Xuất dữ liệu:** Lưu trữ và chia sẻ file .pcap để phân tích sau.

Ứng dụng:

- Phân tích sự cố mạng.
- Kiểm thử bảo mật và phát hiện tấn công.
- Học tập, nghiên cứu giao thức mạng.

Ưu điểm: Miễn phí, hỗ trợ đa nền tảng, giao diện trực quan.

Hạn chế: Yêu cầu kiến thức chuyên môn cao để phân tích dữ liệu, dễ bị quá tải thông tin trong mạng lớn.

2.8 Phát hiện và phòng chống SYN Flooding.

Phát hiện sớm tấn công SYN Flooding là yếu tố quan trọng để giảm thiểu thiệt hại cho hệ thống. Các kỹ thuật sau đây được sử dụng để nhận biết và theo dõi hoạt động bất thường liên quan đến loại hình tấn công này:

- **Phân tích lưu lượng mạng bất thường**: So sánh tỷ lệ giữa các gói tin SYN, SYN-ACK và ACK trong một phiên TCP. Sử dụng các công cụ phân tích gói tin như Wireshark, tcpdump để theo dõi lưu lượng mạng, nếu số lượng gói SYN đến tăng đột biết trong thời gian ngắn, thì máy của bạn đang có thể là mục tiêu của một cuộc tấn công SYN Flooding.
- **Sử dụng hệ thống phát hiện xâm nhập (IDS)** như **Snort, Suricata** hoặc **Zeek.** Các hệ thống này có thể được cấu hình các luật để phát hiện số lượng SYN vượt quá ngưỡng cho phép từ một IP hoặc các gói SYN liên tục mà không có ACK tương ứng.
- **Sử dụng các thiết bị bảo mật chuyên dụng (**như firewall layer 7, NGFW, hoặc DDoS appliance) có thể phát hiện mức SYN cao bất

thường theo thời gian hoặc hành vi bất thường từ các địa chỉ IP riêng lẻ hoặc nhóm địa chỉ.

- **Giám sát nhật ký hệ thống**: nhiều hệ điều hành sẽ log cảnh báo khi backlog queue đầy hoặc có quá nhiều kết nối half-open.

Các phương pháp giảm thiểu hoặc ngăn chặn các cuộc tấn công SYN Flooding:

- **Tăng kích thước hàng đợi kết nối tạm thời (Backlog queue)**: Mỗi hệ điều hành trên thiết bị mục tiêu đều giới hạn số lượng kết nối nửa mở (half-open) mà nó cho phép. Tuy nhiên, để tăng kích thước backlog một cách hiệu quả, hệ thống phải **dự trữ thêm bộ nhớ** để xử lý lượng yêu cầu mới. Nếu hệ thống **không đủ bộ nhớ**, hiệu suất có thể bị ảnh hưởng, nhưng điều này vẫn **tốt hơn việc bị từ chối dịch vụ hoàn toàn (DoS)**.
- **SYN Cookies:** Đây là một phương pháp hiệu quả hơn và an toàn hơn. Máy chủ sử dụng **SYN cookie**, một dạng mã hoá tạm thời thông tin kết nối. Cụ thể khi nhận gói SYN, máy chủ phản hồi bằng gói SYN-ACK, **nhưng không lưu kết nối vào bộ nhớ**. Khi client gửi ACK cuối cùng để hoàn tất bắt tay, **máy chủ mới tái tạo lại thông tin kết nối** dựa trên cookie đã gửi ban đầu. Dù phương pháp này **mất đi một số thông tin phụ** về kết nối TCP (như tùy chọn TCP nâng cao), nhưng nó **hiệu quả trong việc ngăn chặn SYN Flood** mà vẫn phục vụ được kết nối hợp pháp.

2.9 Tổng kết chương 2

Qua các thông tin từ chương 2 có thể thấy rõ rằng tấn công SYN Flooding là một hình thức từ chối dịch vụ (DoS/DDoS) nguy hiểm, có khả năng gây gián đoạn nghiêm trọng đến các hệ thống mạng. Hình thức tấn công này khai thác điểm yếu trong quá trình thiết lập kết nối ba bước (Three-way Handshake) của

giao thức TCP, nhằm làm cạn kiệt tài nguyên của máy chủ mục tiêu thông qua việc tạo ra hàng loạt kết nối "nửa mở" (half-open).

Bên cạnh việc phân loại các hình thức tấn công SYN Flood (trực tiếp, giả mạo địa chỉ IP, và phân tán) đồng thời làm rõ hậu quả nghiêm trọng của loại hình tấn công này đối với hệ thống và doanh nghiệp, bao gồm: gián đoạn dịch vụ, thiệt hại kinh tế, ảnh hưởng đến uy tín thương hiệu, và tạo điều kiện cho các cuộc tấn công phức tạp hơn.

Các phương pháp phát hiện và giảm thiểu SYN Flooding, từ những giải pháp đơn giản như tăng kích thước backlog queue, đến các kỹ thuật nâng cao như SYN cookies, sử dụng IDS, và hệ thống firewall thông minh cũng đã được đề cập.

Những kiến thức lý thuyết đã trình bày ở chương này là nền tảng quan trọng để Nhóm 4 thực hiện các bước kiểm thử, mô phỏng và xây dựng phương án phòng thủ trong phần thực hành tiếp theo của đồ án. Việc hiểu rõ bản chất, cơ chế, tác động và biện pháp ứng phó với SYN Flooding là điều kiện tiên quyết để xây dựng một hệ thống mạng an toàn, ổn định và có khả năng chống chịu cao trước các cuộc tấn công từ chối dịch vụ.

CHƯƠNG 3. KẾT QUẢ THỰC HIỆN

3.1 Kiểm thử khả năng chống chịu tấn công DoS bằng kỹ thuật SYN Flooding theo quy trình PTES

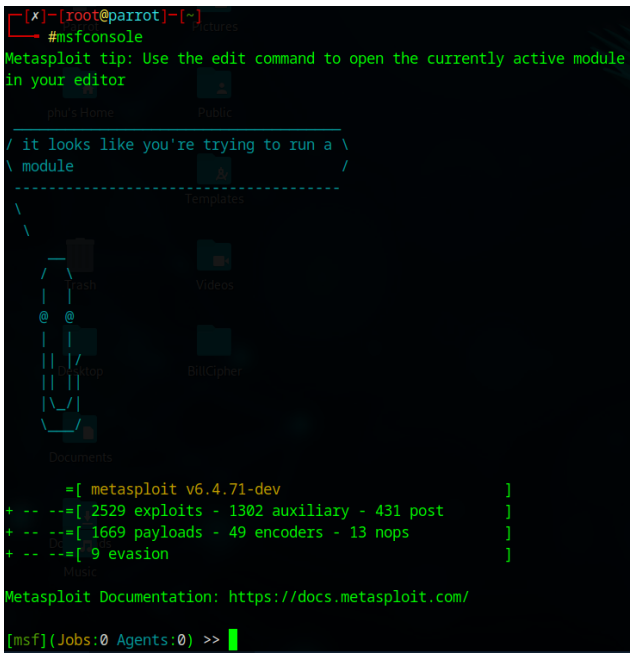
3.1.1 Kịch bản: "Tấn công DoS dịch vụ HTTP bằng Metasploit"

Mô phỏng một cuộc tấn công từ chối dịch vụ (Denial of Service – DoS) **sử dụng kỹ thuật SYN Flood** nhằm gây gián đoạn hoạt động của dịch vụ **HTTP(80)** trên một server nội bộ đang chạy hệ điều hành Linux (Ubuntu) thông qua công cụ Metasploit Framework.

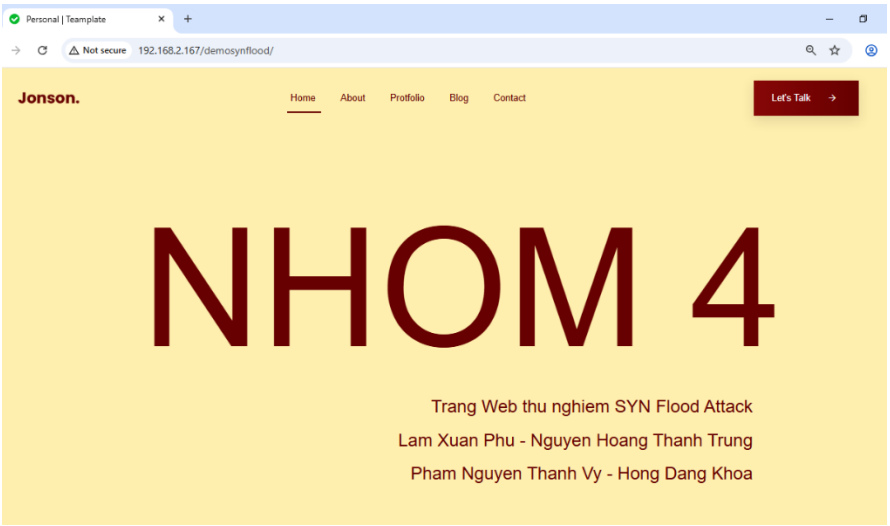
Chuẩn bị môi trường: môi trường thực hiện gồm PC1 (tấn công) và PC2 (nạn nhân)

- PC1 (máy tấn công): Linux, phần mềm tấn công Metasploit, Raven Storm.
- PC2 (máy nạn nhân): Linux có mở HTTP(80). Đồng thời theo dõi bằng Wireshark.

Hình 3.1. Máy tấn công và công cụ tấn công metasploit



Hình 3.2. Máy nạn nhân với dịch vụ web bình thường



Kịch bản tấn công SYN Flooding:

1. Máy tấn công sẽ gửi số lượng lớn gói tin SYN đến Webserver nhằm lợi dụng nguyên tắc bắt tay ba bước mở kết nối đến webserver.
2. Server phản hồi SYN/ACK nhưng máy tấn công sẽ không gửi lại ACK response ➔ Server phải đợi gói ACK response để hoàn thành quá trình 3-ways handshake.
3. Quá trình gửi gói tin SYN request đến Server nhanh và liên tục sẽ khiến Server tràn hàng đợi.

3.1.2 Mô hình kiểm thử

Bảng 3.1. Mô tả thành phần kiểm thử trong kịch bản

Thành phần	Mô tả
Tên ứng dụng	HTTP Web Server (chạy trên Ubuntu)
Kiểu kiểm thử	Kiểm thử từ chối dịch vụ (Denial of Service – SYN Flood)
Kiểu tấn công	Gửi hàng loạt gói SYN đến cổng HTTP (80) gây nghẽn tài nguyên TCP

Thiết bị tấn công	Máy Linux (IP: 192.168.2.166)
Thiết bị mục tiêu	Máy Ubuntu (**IP: 192.168.2.167**)
Dịch vụ bị tấn công	HTTP Server (Port 80)
Công cụ sử dụng	Metasploit Framework, module auxiliary/dos/tcp/synflood
Giao thức bị khai thác	TCP (giai đoạn bắt tay 3 bước: SYN -> SYN/ACK-> ACK)
Điểm vào (Entry Point)	Cổng TCP 80 trên máy Windows
Điểm ra (Exit Point)	Không có phản hồi từ server, HTTP timeout
Quan sát	Wireshark trên máy victim, trình duyệt web
Tác nhân (Attacker)	Máy parrot giả lập gửi gói SYN liên tục
Nạn nhân (Victim)	Dịch vụ web bị nghẽn SYN queue dẫn đến gián đoạn phản hồi
Asset bị đe dọa	Tài nguyên xử lý TCP của server, khả năng phục vụ dịch vụ HTTP
Mức độ ảnh hưởng	Từ chối truy cập tạm thời, gián đoạn hoạt động của web nội bộ
Điều kiện khai thác thành công	Không có SYN cookies, không có giới hạn kết nối SYN
Log và bằng chứng	Lưu lượng SYN lớn bất thường trên Wireshark, HTTP timeout trên trình duyệt
Kết quả mong đợi	Server ngưng phản hồi HTTP khi SYN queue đầy

3.1.3 Giai đoạn 1 – Tiền kiểm thử (Pre-engagement)

Bảng 3.2. Bảng mô tả giai đoạn tiền kiểm thử

Thành phần	Mô tả
Phạm vi kiểm thử	Mạng LAN ảo gồm 2 máy: Kali Linux (attacker) và Linux server (victim)
Mục tiêu	Kiểm tra độ ổn định dịch vụ HTTP khi bị tấn công SYN Flood
Giới hạn	Không được phép tấn công thật, chỉ kiểm thử trong môi trường lab
Nhân lực & công cụ	Dùng **Metasploit, Nmap, Wireshark**
Sơ đồ mạng/IP	Pentester: 192.168.2.166, Server: 192.168.2.167
Trách nhiệm khi sự cố	GVHD giám sát
Kênh liên hệ khẩn cấp	GVHD trực tiếp tại lớp
Biện pháp giảm thiểu rủi ro	Thực hiện trên VM, snapshot trước kiểm thử

3.1.4 Giai đoạn 2 – Thu thập thông tin (Information Gathering)

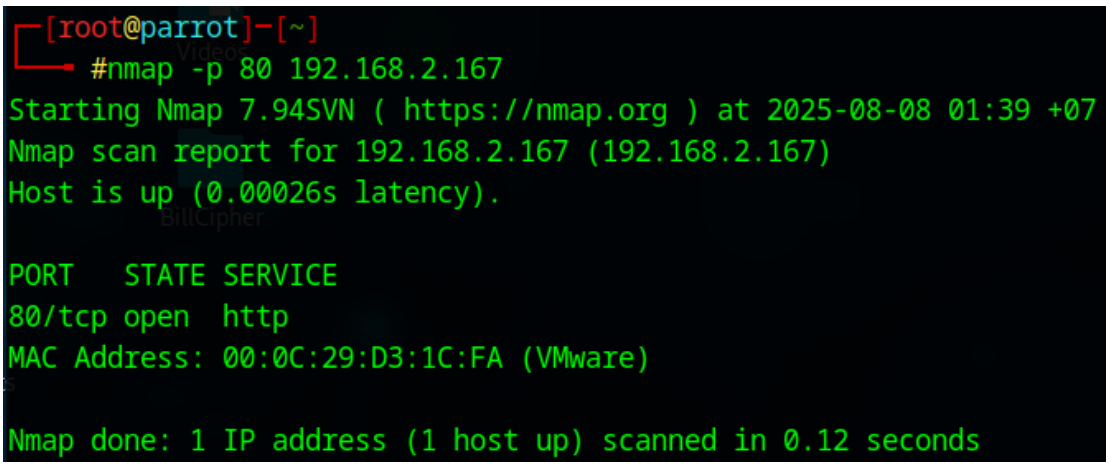
Bảng 3.3. Bảng mô tả gia đoạn thu thập thông tin

Thành phần	Mô tả
OSINT	Không áp dụng vì kiểm thử trong mạng nội bộ

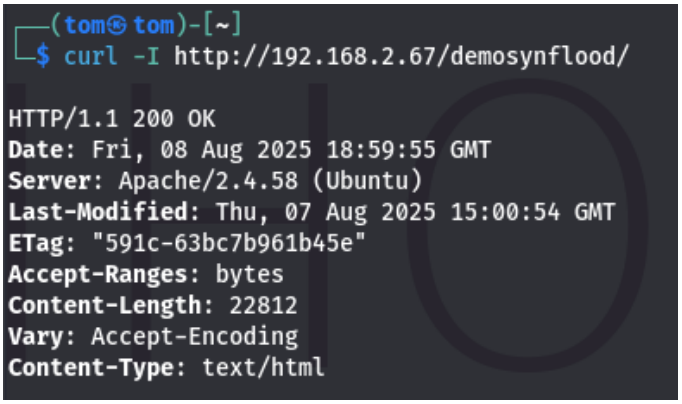
Xác định IP máy victim	IP tĩnh: 192.168.2.167, xác minh bằng netdiscover trong mạng LAN
Footprinting	Sử dụng *nmap -sS -sV -O -p- 192.168.2.167* để xác định cổng, OS, dịch vụ
Reconnaissance (do thám)	Do thám tín hiệu hoạt động của máy chủ mục tiêu bằng lệnh *curl*
Phát hiện hệ điều hành	Ubuntu – xác định qua TTL (~64), *nmap -O* và banner dịch vụ
Scanning	Quét toàn bộ cổng bằng nmap -p-, xác định port 80 mở phục vụ HTTP
Enumeration	Dùng whatweb, curl để liệt kê thông tin HTTP
Chính sách bảo mật	Không phát hiện firewall

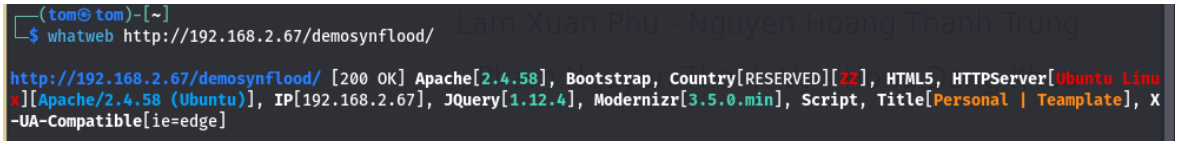
Trên Terminal của máy tấn công, dùng lệnh **nmap -p 80 <IP_mục tiêu>** (Trong bài này, IP là 192.168.2.167 – IP của máy Windows 11). Câu lệnh này sẽ thực hiện quét cổng 80 trên máy Windows để kiểm tra xem cổng có mở và phản hồi hay không.

Hình 3.3. Kiểm tra phản hồi của mục tiêu



Hình 3.4. Do thám bằng lệnh curl và whatwweb





Dựa vào các hình ảnh trên, ta xác nhận máy chủ HTTP hoạt động và có thể là mục tiêu hợp lệ của tấn công DoS, xác định chính xác server web chạy Apache trên nền Ubuntu, thông tin xác thực được mục tiêu HTTP, hỗ trợ đánh giá lỗ hổng liên quan.

3.1.5 Giai đoạn 3 – Mô hình hóa mối đe dọa (Threat Modeling)

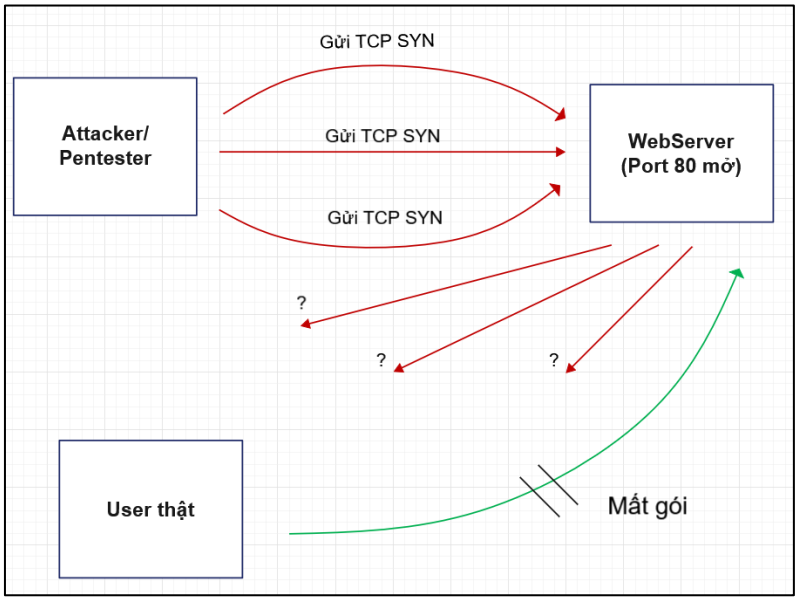
Bảng 3.4. Bảng thành phần trong giai đoạn 3

Thành phần	Mô tả
Attacker	Máy Kali/Parrot (192.168.2.166)
Victim	Máy Linux (192.168.2.167)
Assets	Dịch vụ HTTP (port 80), khả năng phục vụ người dùng
Entry Point	Kết nối TCP qua cổng 80
Exit Point	Kênh TCP không phản hồi hoặc bị nghẽn SYN queue

Trust Level attacker	Toàn quyền trong lab
Trust Level victim	Máy mục tiêu bình thường trong LAN
External Dependency	Cấu hình HTTP không có hạn chế kết nối SYN

DataflowDiagram level 0

Hình 3.5. Mô hình DFD level 0 của tấn công



Bảng STRIDE

Hình 3.6. Bảng mối đe dọa Stride

Loại	Mô tả	Security Control
Spoofing (S)	Kẻ tấn công có thể giả mạo IP nguồn, gây khó khăn cho việc truy vết	Authentication

Tampering (T)	Không có thay đổi dữ liệu trong tấn công SYN Flood	(Không áp dụng)
Repudiation (R)	Kẻ tấn công dùng IP giả khiến hệ thống khó truy vết hoạt động	Non-Repudiation
Information disclosure (I)	Không có dữ liệu nào bị lộ trong quá trình tấn công	(Không áp dụng)
Denial of service (D)	Gửi liên tục gói SYN khiến server từ chối yêu cầu từ người dùng hợp lệ	Availability
Elevation of privilege (E)	Không có việc leo thang quyền trong kịch bản này	(Không áp dụng)

3.1.6 Giai đoạn 4 – Phân tích lỗ hổng (Vulnerability Analysis)

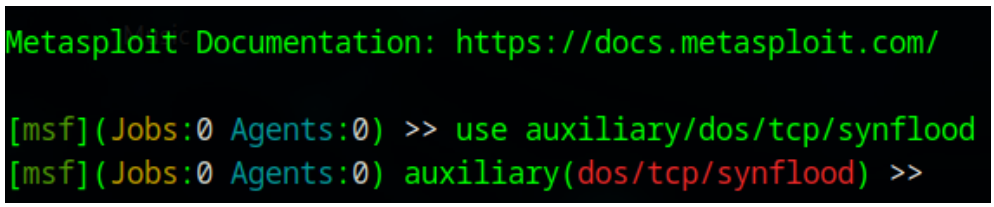
Thành phần	Mô tả
Lỗ hổng chính	Không có bảo vệ SYN Flood trên dịch vụ HTTP
Phát hiện lỗ hổng	Dùng nmap và Wireshark để kiểm tra phản hồi TCP
Phân tích cấu hình	Không giới hạn kết nối đồng thời, SYN queue nhỏ
Mức độ nghiêm trọng	Trung bình – nếu service quan trọng ảnh hưởng lớn
Nguồn gốc	Thiếu cơ chế chống DoS (no SYN cookies, no rate limit)
Ảnh hưởng tiềm tàng	Treo dịch vụ HTTP, ngừng phản hồi

3.1.7 Giai đoạn 5 – Khai thác (Exploitation)

Trên Terminal của máy pentester, gõ lệnh **msfconsole** và bấm ENTER. Màn hình chính của **Metasploit** sẽ hiện ra.

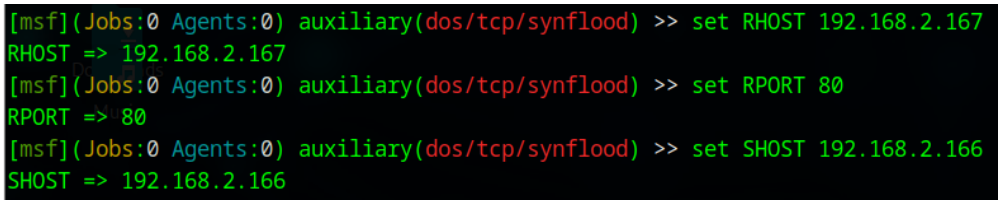
Tải module tấn công SYN Flood bằng cách nhập lệnh **use auxiliary/dos/tcp/synflood** và bấm ENTER.

Hình 3.7. Metasploit chuyển module thành công.



Cấu hình cho các tham số theo hình dưới đây:

Hình 3.8. Cấu hình các tham số cần thiết.

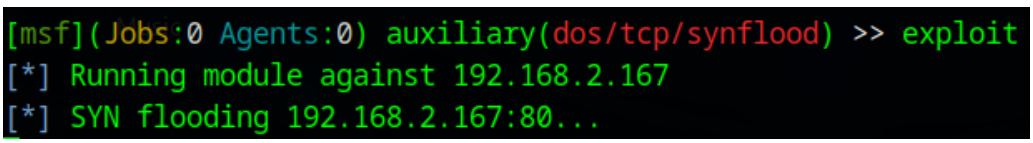


Giải thích các tham số:

- RHOST 192.168.2.167 > IP của máy mục tiêu.
- RPORT 80 > Cổng HTTP
- SHOST 192.168.2.166 > IP của máy Parrot (máy tấn công)

Sau khi hoàn thành cấu hình các thông số, gõ **Exploit** và bấm ENTER.

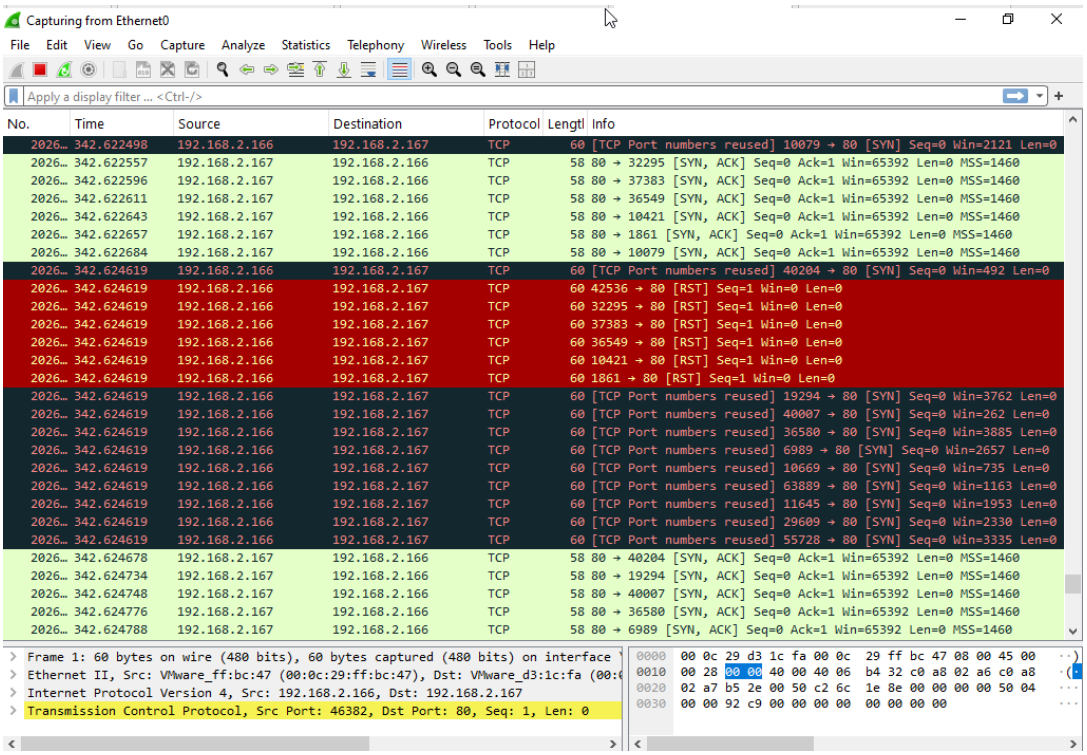
Hình 3.9. Khai thác



Ghi nhận

Trên máy mục tiêu (Windows), mở Wireshark và double click vào đường mạng Ethernet (vì đang xài máy ảo). Ta sẽ phát hiện ra các lưu lượng bất thường có giao thức TCP đến từ IP 192.168.2.166 (IP máy tấn công)

Hình 3.10. Ghi nhận cuộc tấn công từ máy mục tiêu

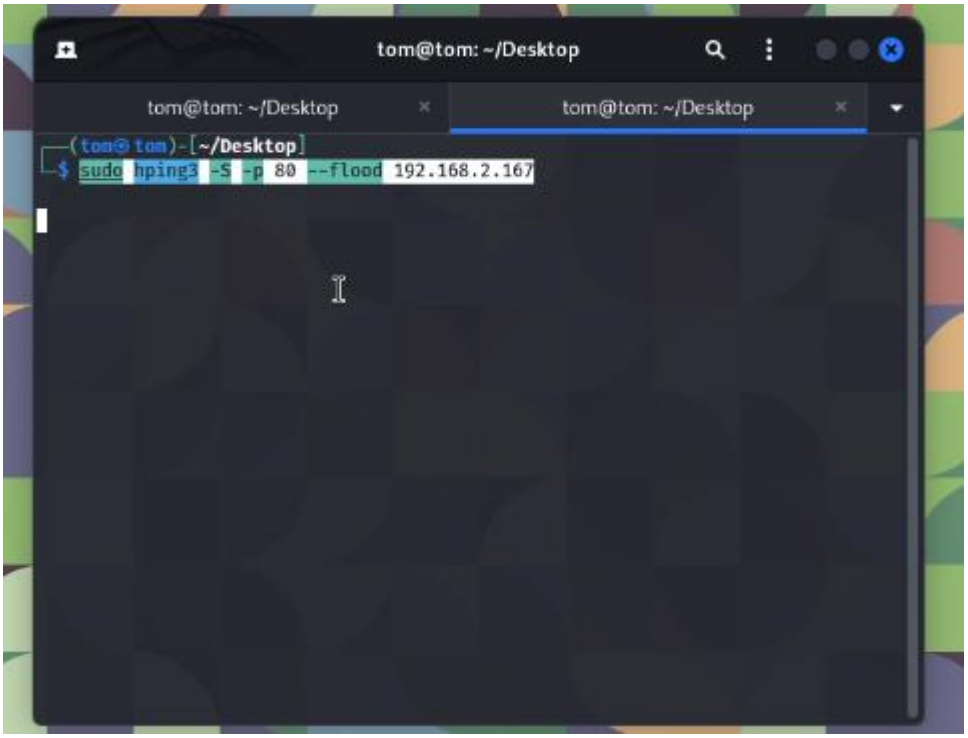


Kết quả

- Máy mục tiêu bắt đầu chậm phản hồi hoặc không thể kết nối từ máy khác.
- Khi tấn công đang diễn ra, trình duyệt truy cập web bị lỗi timeout hoặc tải trang rất lâu.
- Quan sát trên máy mục tiêu cho thấy số lượng kết nối SYN_RECV tăng liên tục, chứng tỏ backlog queue đang bị chiếm dụng.
- CPU và RAM tăng tải, socket mạng hoạt động liên tục do phải xử lý các kết nối nửa mở.
- Dịch vụ web vẫn hoạt động nếu tấn công nhẹ, nhưng sẽ tê liệt tạm thời nếu cường độ SYN Flood cao và kéo dài.

Tiếp tục, sử dụng công cụ hping3 để đa dạng công cụ tấn công synflood,

Hình 3.11. Giao diện tấn công bằng công cụ hping3



Tấn công từ nhiều terminal khác nhau để tăng lưu lượng ➔ dễ làm nghẽn backlog

Lệnh tấn công được sử dụng: **'sudo hping3 -S -p 80 –flood 192.168.2.167'**

Các tùy chọn dòng lệnh được sử dụng:

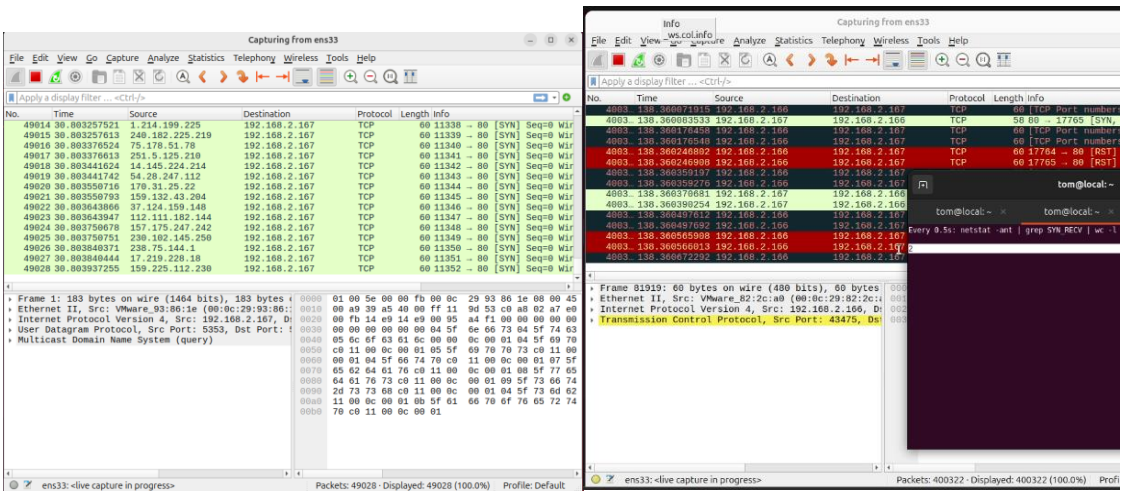
-S: kiểu tấn công SynFlood

-p: xác định port

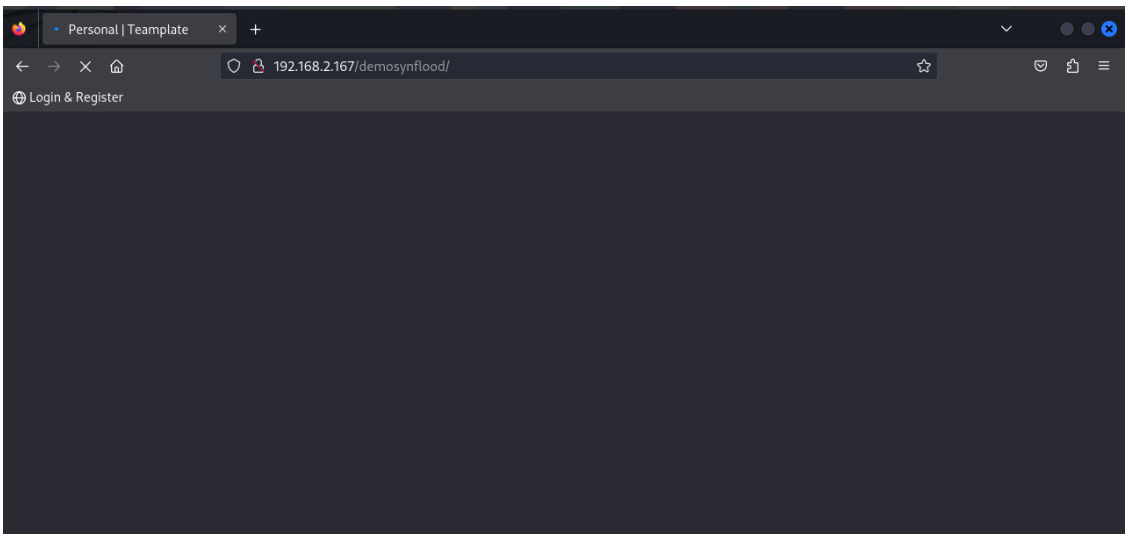
-flood: tùy chọn tốc độ gửi gói liên lục và nhanh.

Quan sát lưu lượng trên máy mục tiêu thấy rõ một lượng lớn gói tin đổ về trong một khoảng thời gian ngắn và backlog bị đầy.

Hình 3.12. Quan sát cuộc tấn công



Hình 3.13. Ảnh hưởng từ cuộc tấn công



Kết quả là **tốc độ tải web chậm hơn rất nhiều** mặc dù nằm trong cùng mạng LAN.

3.1.8 Giai đoạn 6 – Hậu khai thác (Post-exploitation)

Mặc dù là một hình thức tấn công mạng nhưng SYN Flooding không có giai đoạn hậu khai thác. Lý do là vì mục tiêu của SYN Flood là làm cạn kiệt tài nguyên hệ thống, ngăn dịch vụ phản hồi, chứ không phải khai thác lỗ hổng để chiếm quyền điều khiển. Do đó, nó không tạo ra quyền truy cập vào hệ thống và không thể triển khai các hoạt động sau khi xâm nhập.

Tuy nhiên, kẻ tấn công có thể sử dụng SYN Flood song song với các hình thức tấn công khác, ví dụ:

- Trong khi hệ thống đang bận xử lý SYN Flood, kẻ tấn công có thể đồng thời thực hiện Brute force, SQL Injection,... mà khó bị phát hiện.
- Hoặc kết hợp SYN Flood với các hình thức DoS khác để gây sập hạ tầng, sau đó tiến hành xâm nhập.

3.1.9 Giai đoạn 7 – Tổng kết

Tổng hợp kết quả: Qua quá trình thực hiện tấn công SYN Flood vào dịch vụ HTTP (cổng 80) của máy mục tiêu, hệ thống ghi nhận được các chỉ số tài nguyên như sau:

- **CPU:** Tăng lên mức 99% và duy trì gần mức tối đa trong suốt thời gian tấn công. Điều này cho thấy CPU phải xử lý số lượng lớn gói SYN và duy trì các kết nối nửa mở (half-open connections).
- **Memory:** Sử dụng khoảng 1.4 GB / 2.0 GB (70.6%), tăng đáng kể so với trạng thái bình thường. Cho thấy backlog queue và các tiến trình xử lý TCP tiêu tốn nhiều bộ nhớ.
- **Swap:** Sử dụng 595.7 MB (15.2% của 3.9 GB). Hệ thống bắt đầu sử dụng bộ nhớ swap để bù đắp thiếu hụt RAM vật lý, gây ảnh hưởng hiệu năng.
- **Network:**
  - Receiving: 888.8 MiB tổng cộng, lưu lượng nhận liên tục ở mức cao.
  - Sending: Hầu như không gửi dữ liệu đáng kể (0 B/s), vì SYN Flood không yêu cầu hoàn tất bắt tay TCP. Lượng dữ liệu nhận cao nhưng phản hồi gửi đi rất thấp, đúng với cơ chế của SYN Flood.
- **Hiệu ứng quan sát được:**
  - Truy cập website chậm rõ rệt.
  - Hệ thống có độ trễ cao khi thực hiện các tác vụ mạng khác.

Đánh giá rủi ro: dựa trên kết quả thu được, có thể đánh giá mức độ rủi ro của hệ thống như sau:

- **Mức độ tác động:**
  - CPU và bộ nhớ bị chiếm dụng ở mức cao, gây giảm hiệu suất toàn bộ hệ thống.
  - Dịch vụ web trở nên chậm hoặc không phản hồi, gây gián đoạn truy cập cho người dùng hợp pháp.
- **Khả năng khai thác:**
  - SYN Flood không yêu cầu quyền truy cập vào hệ thống mục tiêu, chỉ cần kết nối mạng và cổng dịch vụ mở.
  - Dễ thực hiện bằng các công cụ phổ biến như Metasploit, hping3.
- **Hậu quả tiềm ẩn:**
  - **Gián đoạn dịch vụ:** Website hoặc API không thể phục vụ yêu cầu hợp pháp.
  - **Tổn thất kinh doanh:** Mất khách hàng, doanh thu giảm trong thời gian ngừng dịch vụ.
  - **Uy tín giảm**: Người dùng đánh giá hệ thống kém ổn định.
  - **Tạo điều kiện cho tấn công phối hợp:** Trong lúc hệ thống quá tải, kẻ tấn công có thể thực hiện các kỹ thuật khác như khai thác lỗ hổng ứng dụng.
- **Nguyên nhân dễ bị tấn công:**
  - Chưa bật hoặc cấu hình **SYN Cookies** để giảm tác động của SYN Flood.
  - Không giới hạn kết nối theo IP nguồn.
  - Thiếu hệ thống phát hiện và ngăn chặn tấn công DoS/DDoS (IDS/IPS, firewall thông minh).

3.2 Giải pháp phòng chống

Để phòng chống SYN Flood, ta có thể thực hiện những điều sau:

Bảo vệ ở mức hệ điều hành.

- Kích hoạt SYN Cookies cho phép máy chủ chỉ lưu trạng thái kết nối khi nhận được gói ACK hợp lệ, tránh backlog queue bị chiếm dụng
- Giảm thời gian chờ kết nối half-open (SYN timeout): rút ngắn thời gian duy trì kết nối nửa mở để giải phóng tài nguyên nhanh hơn.
- Tăng kích thước backlog queue: giúp xử lý nhiều kết nối nửa mở hơn trước khi bị quá tải.

Giới hạn và lọc kết nối.

- Giới hạn số kết nối SYN từ mỗi IP bằng firewall.
- Chặn hoặc làm chậm các IP gửi SYN bất thường.
- Lọc IP giả mạo (IP spoofing) tại router hoặc firewall.

Sử dụng thiết bị bảo mật chuyên dụng.

- Sử dụng IDS/IPS (Snort, Suricata, Zeek) để phát hiện và cảnh báo khi có lưu lượng SYN bất thường.
- Sử dụng Firewall thông minh có tích hợp cơ chế chống DoS/DdoS ở lớp 4 và lớp 7

Bảo vệ ở tầng mạng và hạ tầng.

- Load Balancer: Phân tán lưu lượng đến nhiều máy chủ để giảm tải.
- Dịch vụ chống DDoS từ nhà cung cấp (Cloudflare, AWS Shield, Akamai): Lọc lưu lượng SYN trước khi đến hệ thống thật.

Quy trình giám sát và ứng phó.

- Giám sát lưu lượng mạng liên tục để phát hiện sớm SYN Flood.
- Thiết lập cảnh báo tự động khi tỷ lệ SYN/SYN-ACK/ACK bất thường.
- Kế hoạch ứng phó sự cố để cách ly hoặc chặn nguồn tấn công kịp thời.

3.3 Tổng kết chương 3

Qua quá trình kiểm thử khả năng chống chịu tấn công DoS bằng kỹ thuật SYN Flooding theo quy trình PTES, nhóm đã thực hiện đầy đủ các giai đoạn từ tiền kiểm thử, thu thập thông tin, mô hình hóa mối đe dọa, phân tích lỗ hổng, khai thác, ghi nhận kết quả, đến đánh giá rủi ro và đề xuất giải pháp phòng chống.

Về hiệu quả kiểm thử:

- Môi trường lab được cấu hình hợp lý, đảm bảo an toàn, không ảnh hưởng đến hệ thống thực tế.
- Các công cụ được sử dụng (Metasploit Framework, Raven-Storm, Nmap, Wireshark) hoạt động ổn định và cho kết quả rõ ràng, minh chứng được tác động của SYN Flood lên dịch vụ HTTP.
- Quá trình khai thác thành công tái hiện hiện tượng backlog queue bị chiếm dụng, dẫn đến dịch vụ web chậm phản hồi, nhiều lần timeout và tài nguyên hệ thống (CPU, RAM) bị tiêu tốn đáng kể.

Về mức độ ảnh hưởng:

- Kịch bản kiểm thử đã chứng minh được rằng chỉ với một nguồn tấn công trong mạng LAN, dịch vụ HTTP trên máy mục tiêu đã bị ảnh hưởng rõ rệt.
- Mức độ rủi ro cao hơn nếu tấn công được thực hiện từ nhiều nguồn (DDoS) hoặc cường độ gửi gói SYN tăng mạnh.
- Các thông số thu thập được (CPU 99%, RAM 70%, backlog queue đầy, kết nối SYN_RECV tăng liên tục) là minh chứng cụ thể về tác động tiêu cực của tấn công.

Về hạn chế:

- Bài kiểm thử chỉ dừng ở mức làm giảm tốc độ và khả năng phản hồi của dịch vụ web, chưa đạt đến mức "ngưng phục vụ hoàn toàn" do giới hạn tài nguyên tấn công và cơ chế bảo vệ mặc định của hệ điều hành mục tiêu.
- Chưa mô phỏng được tấn công đa nguồn (DDoS) – vốn là kịch bản phổ biến và nguy hiểm hơn trong thực tế.

- Một số chỉ số giám sát (log hệ thống, biểu đồ lưu lượng) có thể được thu thập và trình bày chi tiết hơn để tăng tính trực quan của báo cáo.

Nhận định tổng quát:

- Hệ thống mục tiêu trong cấu hình hiện tại dễ bị ảnh hưởng bởi SYN Flooding khi không có các biện pháp phòng thủ như SYN Cookies, giới hạn kết nối, hoặc firewall thông minh.
- Việc áp dụng các giải pháp phòng chống đề xuất trong mục 3.2 là cần thiết để tăng khả năng chống chịu, đặc biệt đối với môi trường sản xuất.
- Bài kiểm thử đạt được mục tiêu đánh giá khả năng phòng thủ của hệ thống và cung cấp cơ sở thực tiễn để triển khai biện pháp bảo vệ phù hợp.

CHƯƠNG 4. KẾT LUẬN

Qua quá trình nghiên cứu và thực nghiệm, nhóm đã hoàn thành đầy đủ các nội dung của đề tài **"Đánh giá khả năng chống chịu tấn công từ chối dịch vụ bằng kỹ thuật SYN Flooding theo PTES"**.

Về **lý thuyết**, báo cáo đã trình bày rõ:

- Khái niệm và nguyên lý hoạt động của giao thức TCP với cơ chế bắt tay ba bước (Three-way Handshake) – điểm mấu chốt bị khai thác trong tấn công SYN Flooding.
- Bản chất, phương thức hoạt động, các loại hình, và hậu quả của SYN Flooding đối với hệ thống mạng.
- Các công cụ kiểm thử phổ biến như Metasploit, Nmap, Wireshark và cách sử dụng chúng trong quá trình đánh giá an ninh.
- Các phương pháp phát hiện và phòng chống SYN Flooding ở nhiều lớp (hệ điều hành, mạng, thiết bị bảo mật, dịch vụ chống DDoS).

Về **thực nghiệm**, nhóm đã:

- Xây dựng môi trường kiểm thử an toàn trong mô hình ảo hóa để mô phỏng tấn công SYN Flooding vào dịch vụ HTTP (cổng 80) theo đúng quy trình PTES.
- Thực hiện thành công các giai đoạn từ tiền kiểm thử, thu thập thông tin, mô hình hóa mối đe dọa, phân tích lỗ hổng, khai thác, ghi nhận kết quả, đến đánh giá rủi ro.
- Thu thập được các số liệu minh chứng rõ ràng cho tác động của SYN Flooding: CPU tăng đến 99%, RAM sử dụng 70%, backlog queue bị chiếm dụng, kết nối SYN_RECV tăng nhanh, dịch vụ web chậm hoặc tạm ngừng phản hồi.
- Đưa ra các giải pháp phòng chống cụ thể và khả thi nhằm nâng cao khả năng chống chịu của hệ thống.

Nhận xét chung:

- Tấn công SYN Flooding là mối đe dọa nghiêm trọng đối với tính sẵn sàng của dịch vụ mạng.

- Ngay cả trong môi trường nội bộ, một nguồn tấn công cũng có thể làm suy giảm đáng kể hiệu năng hệ thống nếu không có biện pháp bảo vệ.
- Việc áp dụng các kỹ thuật phòng thủ như SYN Cookies, giới hạn kết nối, lọc gói tin bất thường, và triển khai IDS/IPS là cần thiết để bảo vệ dịch vụ mạng trong thực tế.

Hướng phát triển:

- Mở rộng kiểm thử với kịch bản tấn công DDoS đa nguồn để đánh giá chính xác hơn sức chịu đựng của hệ thống.
- Tích hợp thêm các công cụ giám sát nâng cao để thu thập và phân tích dữ liệu trực quan hơn.
- Thử nghiệm biện pháp phòng chống ngay trong môi trường tấn công để đánh giá hiệu quả thực tế của từng giải pháp.

Bằng việc thực hiện đề tài này, nhóm không chỉ đạt được mục tiêu kiểm thử và đánh giá, mà còn củng cố kiến thức, kỹ năng triển khai và ứng phó với một trong những hình thức tấn công mạng phổ biến và nguy hiểm hiện nay.

TÀI LIỆU THAM KHẢO

Tài liệu hướng dẫn học (Manual):

[1] EC-Council, CEH v12 Lab Manual, EC-Council, 2022.

Bài viết trực tuyến (Online Article):

[2] Akamai, "What Are SYN Flood DDoS Attacks?", Akamai Glossary, 2025. [Online]. Available: https://www.akamai.com/glossary/what-are-syn-flood-ddos-attacks

[3] Tenten, “DDoS/DoS là gì? Giải pháp phòng chống tấn công DDoS,” Tenten News, Mar. 22, 2021. [Online]. Available: https://tenten.vn/tin-tuc/ddos-dos-la-gi-giai-phap-phong-chong-tan-cong-ddos/

[4] SYN flood attack - A SYN flood exploits a vulnerability in the TCP/IP handshake in an attempt to disrupt a web service. Available: https://www.cloudflare.com/learning/ddos/syn-flood-ddos-attack/